



ZAP by
Checkmarx

ZAP by Checkmarx Scanning Report

Sites: <https://edge-consumer-static.azureedge.net> <http://localhost:8080>
<https://editor.svc.cloud.microsoft> <https://fonts.gstatic.com> <https://fonts.googleapis.com> <https://telem-edge.smartscreen.microsoft.com>
<https://www.bing.com> <https://data-edge.smartscreen.microsoft.com>
<http://msedge.f.tlu.dl.delivery.mp.microsoft.com> <https://www.googleapis.com> <http://localhost:5173> <https://nav-edge.smartscreen.microsoft.com>
<https://edge.microsoft.com> <http://edge.microsoft.com>

Generated on Mon, 22 Jun 2026 23:10:15

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	2
Medium	3
Low	12
Informational	9

Alerts

Name	Risk Level	Number of Instances
Cross Site Scripting (Reflected)	High	1
SQL Injection	High	2
Content Security Policy (CSP) Header Not Set	Medium	2
Cross-Domain Misconfiguration	Medium	5
Missing Anti-clickjacking Header	Medium	2
Cookie No HttpOnly Flag	Low	1
Cookie Without Secure Flag	Low	3
Cookie with SameSite Attribute None	Low	1
Cookie without SameSite Attribute	Low	3
Private IP Disclosure	Low	1
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	2
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	1
Strict-Transport-Security Disabled	Low	1

Strict-Transport-Security Header Not Set	Low	Systemic
Timestamp Disclosure - Unix	Low	Systemic
X-AspNet-Version Response Header	Low	4
X-Content-Type-Options Header Missing	Low	Systemic
Authentication Request Identified	Informational	1
Information Disclosure - Sensitive Information in URL	Informational	1
Information Disclosure - Suspicious Comments	Informational	10
Loosely Scoped Cookie	Informational	1
Modern Web Application	Informational	1
Re-examine Cache-control Directives	Informational	6
Retrieved from Cache	Informational	5
Session Management Response Identified	Informational	1
User Agent Fuzzer	Informational	Systemic

Alert Detail

High	Cross Site Scripting (Reflected)
Description	Cross-site Scripting (XSS) is an attack technique that involves echoing attacker-supplied code into a user's browser instance. A browser instance can be a standard web browser client, or a browser object embedded in a software product such as the browser within WinAmp, an RSS reader, or an email client. The code itself is usually written in HTML /JavaScript, but may also extend to VBScript, ActiveX, Java, Flash, or any other browser-supported technology. When an attacker gets a user's browser to execute his/her code, the code will run within the security context (or zone) of the hosting web site. With this level of privilege, the code has the ability to read, modify and transmit any sensitive data accessible by the browser. A Cross-site Scripted user could have his/her account hijacked (cookie theft), their browser redirected to another location, or possibly shown fraudulent content delivered by the web site they are visiting. Cross-site Scripting attacks essentially compromise the trust relationship between a user and the web site. Applications utilizing browser object instances which load content from the file system may execute code under the local machine zone allowing for system compromise. There are three types of Cross-site Scripting attacks: non-persistent, persistent and DOM-based. Non-persistent attacks and DOM-based attacks require a user to either visit a specially crafted link laced with malicious code, or visit a malicious web page containing a web form, which when posted to the vulnerable site, will mount the attack. Using a malicious form will oftentimes take place when the vulnerable resource only accepts HTTP POST requests. In such a case, the form can be submitted automatically, without the victim's knowledge (e.g. by using JavaScript). Upon clicking on the malicious link or submitting the malicious form, the XSS payload will get echoed back and will get interpreted by the user's browser and execute. Another technique to send almost arbitrary requests (GET and POST) is by using an embedded client, such as Adobe Flash. Persistent attacks occur when the malicious code is submitted to a web site where it's stored for a period of time. Examples of an attacker's favorite targets often include message board posts, web mail messages, and web chat software. The unsuspecting user is not required to interact with any additional site/link (e.g. an attacker site or a malicious link sent via email), just simply view the web page containing the code.
URL	http://localhost:8080/api/greet?name=%3C%2Fspan%3E%3Cscript%3Ealert%281%29%3B%3C%2Fscript%3E%3Cspan%3E
Node Name	http://localhost:8080/api/greet (name)

Method	GET
Attack	<code><script>alert(1);</script></code>
Evidence	<code><script>alert(1);</script></code>
Other Info	
Instances	1
Solution	Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. Examples of libraries and frameworks that make it easier to generate properly encoded output include Microsoft's Anti-XSS library, the OWASP ESAPI Encoding module, and Apache Wicket. Phases: Implementation; Architecture and Design Understand the context in which your data will be used and the encoding that will be expected. This is especially important when transmitting data between different components, or when generating outputs that can contain multiple encodings at the same time, such as web pages or multi-part mail messages. Study all expected communication protocols and data representations to determine the required encoding strategies. For any data that will be output to another web page, especially any data that was received from external inputs, use the appropriate encoding on all non-alphanumeric characters. Consult the XSS Prevention Cheat Sheet for more details on the types of encoding and escaping that are needed. Phase: Architecture and Design For any security checks that are performed on the client side, ensure that these checks are duplicated on the server side, in order to avoid CWE-602. Attackers can bypass the client-side checks by modifying values after the checks have been performed, or by changing the client to remove the client-side checks entirely. Then, these modified values would be submitted to the server. If available, use structured mechanisms that automatically enforce the separation between data and code. These mechanisms may be able to provide the relevant quoting, encoding, and validation automatically, instead of relying on the developer to provide this capability at every point where output is generated. Phase: Implementation For every web page that is generated, use and specify a character encoding such as ISO-8859-1 or UTF-8. When an encoding is not specified, the web browser may choose a different encoding by guessing which encoding is actually being used by the web page. This can cause the web browser to treat certain sequences as special, opening up the client to subtle XSS attacks. See CWE-116 for more mitigations related to encoding/escaping. To help mitigate XSS attacks against the user's session cookie, set the session cookie to be HttpOnly. In browsers that support the HttpOnly feature (such as more recent versions of Internet Explorer and Firefox), this attribute can prevent the user's session cookie from being accessible to malicious client-side scripts that use document.cookie. This is not a complete solution, since HttpOnly is not supported by all browsers. More importantly, XMLHttpRequest and other powerful browser technologies provide read access to HTTP headers, including the Set-Cookie header in which the HttpOnly flag is set. Assume all input is malicious. Use an "accept known good" input validation strategy, i.e., use an allow list of acceptable inputs that strictly conform to specifications. Reject any input that does not strictly conform to specifications, or transform it into something that does. Do not rely exclusively on looking for malicious or malformed inputs (i.e., do not rely on a deny list). However, deny lists can be useful for detecting potential attacks or determining which inputs are so malformed that they should be rejected outright.

	When performing input validation, consider all potentially relevant properties, including length, type of input, the full range of acceptable values, missing or extra inputs, syntax, consistency across related fields, and conformance to business rules. As an example of business rule logic, "boat" may be syntactically valid because it only contains alphanumeric characters, but it is not valid if you are expecting colors such as "red" or "blue." Ensure that you perform input validation at well-defined interfaces within the application. This will help protect the application even if a component is reused or moved elsewhere.
Reference	https://owasp.org/www-community/attacks/xss/ https://cwe.mitre.org/data/definitions/79.html
CWE Id	79
WASC Id	8
Plugin Id	40012

High	SQL Injection
Description	SQL injection may be possible.
URL	http://localhost:8080/api/login
Node Name	http://localhost:8080/api/login ()(password,username)
Method	POST
Attack	p' OR '1'='1' --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [p' AND '1'='1' --] and [p' OR '1'='1' --] The parameter value being modified was stripped from the HTML output for the purposes of the comparison. Data was NOT returned for the original parameter. The vulnerability was detected by successfully retrieving more data than originally returned, by manipulating the parameter.
URL	http://localhost:8080/api/login
Node Name	http://localhost:8080/api/login ()(password,username)
Method	POST
Attack	a' OR '1'='1' --
Evidence	
Other Info	The page results were successfully manipulated using the boolean conditions [a' AND '1'='1' --] and [a' OR '1'='1' --] The parameter value being modified was stripped from the HTML output for the purposes of the comparison. Data was NOT returned for the original parameter. The vulnerability was detected by successfully retrieving more data than originally returned, by manipulating the parameter.
Instances	2
Solution	Do not trust client side input, even if there is client side validation in place. In general, type check all data on the server side. If the application uses JDBC, use PreparedStatement or CallableStatement, with parameters passed by '?' If the application uses ASP, use ADO Command Objects with strong type checking and parameterized queries. If database Stored Procedures can be used, use them. Do *not* concatenate strings into queries in the stored procedure, or use 'exec', 'exec immediate', or equivalent functionality!

	Do not create dynamic SQL queries using simple string concatenation. Escape all data received from the client. Apply an 'allow list' of allowed characters, or a 'deny list' of disallowed characters in user input. Apply the principle of least privilege by using the least privileged database user possible. In particular, avoid using the 'sa' or 'db-owner' database users. This does not eliminate SQL injection, but minimizes its impact. Grant the minimum database access that is necessary for the application.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
CWE Id	89
WASC Id	19
Plugin Id	40018

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:5173/
Node Name	http://localhost:5173/
Method	GET
Attack	
Evidence	
Other Info	
URL	http://localhost:8080/api/greet?name=a
Node Name	http://localhost:8080/api/greet (name)
Method	GET
Attack	
Evidence	
Other Info	
Instances	2
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/

CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Cross-Domain Misconfiguration
Description	Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server.
URL	https://edge-consumer-static.azureedge.net/mouse-gesture/config.json
Node Name	https://edge-consumer-static.azureedge.net/mouse-gesture/config.json
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://fonts.googleapis.com/css2?family=Inter:wght@400;500;600;700&family=JetBrains+Mono:wght@400;500&display=swap
Node Name	https://fonts.googleapis.com/css2 (display,family,family)
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://fonts.gstatic.com/s/inter/v20/UcC73FwrK3iLTeHuS_nVMrMxCp50Sjla1ZL7.woff2
Node Name	https://fonts.gstatic.com/s/inter/v20/UcC73FwrK3iLTeHuS_nVMrMxCp50Sjla1ZL7.woff2
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	https://fonts.gstatic.com/s/jetbrainsmono/v24/tDbv2o-flEEEny0FZhsfKu5WU4zr3E_BX0PnT8RD8yKwBNntkaToggR7BYRbKPxDcwg.woff2
Node Name	https://fonts.gstatic.com/s/jetbrainsmono/v24/tDbv2o-flEEEny0FZhsfKu5WU4zr3E_BX0PnT8RD8yKwBNntkaToggR7BYRbKPxDcwg.woff2
Method	GET
Attack	
Evidence	Access-Control-Allow-Origin: *

Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
URL	http://localhost:8080/api/login
Node Name	http://localhost:8080/api/login ()(password,username)
Method	POST
Attack	
Evidence	Access-Control-Allow-Origin: *
Other Info	The CORS misconfiguration on the web server permits cross-domain read requests from arbitrary third party domains, using unauthenticated APIs on this domain. Web browser implementations do not permit arbitrary third parties to read the response from authenticated APIs, however. This reduces the risk somewhat. This misconfiguration could be used by an attacker to access data that is available in an unauthenticated manner, but which uses some other form of security, such as IP address white-listing.
Instances	5
Solution	Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.
Reference	https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
CWE Id	264
WASC Id	14
Plugin Id	10098

Medium	Missing Anti-clickjacking Header
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://localhost:5173/
Node Name	http://localhost:5173/
Method	GET
Attack	
Evidence	
Other Info	
URL	http://localhost:8080/api/greet?name=a
Node Name	http://localhost:8080/api/greet (name)
Method	GET
Attack	
Evidence	
Other Info	
Instances	2

Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Low	Cookie No HttpOnly Flag
Description	A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.
URL	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Node Name	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Method	GET
Attack	
Evidence	Set-Cookie: MUID
Other Info	
Instances	1
Solution	Ensure that the HttpOnly flag is set for all cookies.
Reference	https://owasp.org/www-community/HttpOnly
CWE Id	1004
WASC Id	13
Plugin Id	10010

Low	Cookie Without Secure Flag
Description	A cookie has been set without the secure flag, which means that the cookie can be accessed via unencrypted connections.
URL	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Node Name	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Method	GET
Attack	
Evidence	Set-Cookie: _EDGE_S
Other Info	
URL	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Node Name	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Method	GET
Attack	
Evidence	Set-Cookie: _EDGE_V

Other Info	
URL	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Node Name	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Method	GET
Attack	
Evidence	Set-Cookie: MUIDB
Other Info	
Instances	3
Solution	Whenever a cookie contains sensitive information or is a session token, then it should always be passed using an encrypted channel. Ensure that the secure flag is set for cookies containing such sensitive information.
Reference	https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html
CWE Id	614
WASC Id	13
Plugin Id	10011

Low	Cookie with SameSite Attribute None
Description	A cookie has been set with its SameSite attribute set to "none", which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
URL	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Node Name	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Method	GET
Attack	
Evidence	Set-Cookie: MUID
Other Info	
Instances	1
Solution	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.
Reference	https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
CWE Id	1275
WASC Id	13
Plugin Id	10054

Low	Cookie without SameSite Attribute
Description	A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
URL	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Node Name	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Method	GET

Attack	
Evidence	Set-Cookie: _EDGE_S
Other Info	
URL	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Node Name	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Method	GET
Attack	
Evidence	Set-Cookie: _EDGE_V
Other Info	
URL	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Node Name	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Method	GET
Attack	
Evidence	Set-Cookie: MUIDB
Other Info	
Instances	3
Solution	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.
Reference	https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
CWE Id	1275
WASC Id	13
Plugin Id	10054

Low	Private IP Disclosure
Description	A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for 78) has been found in the HTTP response body. This information might be helpful for further attacks on systems.
URL	https://edge.microsoft.com/componentupdater/api/v1/update?cup2key=7:uPihYU31fGMV_DwLcOHQzI7CUwh5Xs1ODs3QUJM&cup2hreq=7817013f8aaf368ac3c2f4b43b292fd2f3dba482bb3e
Node Name	https://edge.microsoft.com/componentupdater/api/v1/update (cup2hreq,cup2key)({request:{@os:acceptformat,apps:[{appid,brand,cohort,enabled,installdate,lang,ping:{r},targetingattributes:{AppMajorVersion,AppRollout,AppVersion,IsInternalUser,Priority,Updater,UpdaterVersion}},update:{appid,brand,cached_items:[{sha256}],cohort,enabled,installdate,lang,ping:{r},targetingattributes:{AppMajorVersion,AppRollout,AppVersion,IsInternalUser,Priority,Updater,UpdaterVersion}},update:{appid,brand,cached_items:[{sha256}],cohort,enabled...})
Method	POST
Attack	
Evidence	10.34.0.84
Other Info	10.34.0.84
Instances	1
Solution	Remove the private IP address from the HTTP response body. For comments, use JSP/ASP/PHP/HTML/JavaScript comment which can be seen by client browsers.
Reference	https://datatracker.ietf.org/doc/html/rfc1918

CWE Id	497
WASC Id	13
Plugin Id	2

Low	Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)
Description	The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.
URL	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/2b43081f-d6ff-4406-bbb9-c327fccbcb45?P1=1782329345&P2=404&P3=2&P4=F1VxUvS9DQm388w%2b2Xy8S1Eo7vIAb3iXkhQY4Ox16ZYPvY2GsE8%2bL0RakrsAP4vQ%2fIPj%2b84ZVM5ylAMz9iOP5Q%3d%3d
Node Name	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/2b43081f-d6ff-4406-bbb9-c327fccbcb45 (P1,P2,P3,P4)
Method	GET
Attack	
Evidence	X-Powered-By: ASP.NET
Other Info	The following X-Powered-By headers were also found: X-Powered-By: ARR/3.0 X-Powered-By: ASP.NET
URL	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/954c48e2-6a88-44a1-a49e-0fcfaad93f67?P1=1782374071&P2=404&P3=2&P4=BaYf3mCTpsayJ0bhgiEzMu%2b3U3SdGMSRpuAnCFXUOaxyRNIDGoANYuF2oAO01zev0O38xSnXI5y4Ao50eTUw%3d%3d
Node Name	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/954c48e2-6a88-44a1-a49e-0fcfaad93f67 (P1,P2,P3,P4)
Method	GET
Attack	
Evidence	X-Powered-By: ASP.NET
Other Info	The following X-Powered-By headers were also found: X-Powered-By: ARR/3.0 X-Powered-By: ASP.NET
Instances	2
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.
Reference	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10037

Low	Server Leaks Version Information via "Server" HTTP Response Header Field
Description	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.
URL	https://editor.svc.cloud.microsoft/NLEditor/TileCheck/V1
Node Name	https://editor.svc.cloud.microsoft/NLEditor/TileCheck/V1 ()({{SessionId,ApplId,LanguageUxId,Content:[{TileId,RevisionId,TileElements:[{LanguageId,Text,TextUnit}]}],Descriptors:[{Name,Value}..]})
Method	POST

Attack	
Evidence	Microsoft-HTTPAPI/2.0
Other Info	
Instances	1
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.
Reference	https://httpd.apache.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10036

Low	Strict-Transport-Security Disabled
Description	A HTTP Strict Transport Security (HSTS) header was found, but it contains the directive max-age=0 which disables the control and instructs browsers to reset any previous HSTS related settings. See RFC 6797 for further details. HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL).
URL	https://edge.microsoft.com/abusiveadblocking/api/v1/blocklist
Node Name	https://edge.microsoft.com/abusiveadblocking/api/v1/blocklist
Method	GET
Attack	
Evidence	max-age=0
Other Info	
Instances	1
Solution	Review the configuration of this control. Ensure that your web server, application server, load balancer, etc. is configured to set Strict-Transport-Security with an appropriate max-age value.
Reference	https://datatracker.ietf.org/doc/html/rfc6797#section-6.2
CWE Id	319
WASC Id	15
Plugin Id	10035

Low	Strict-Transport-Security Header Not Set
Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web serv web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered ov protocol and is specified in RFC 6797.
URL	https://edge-consumer-static.azureedge.net/mouse-gesture/config.json
Node Name	https://edge-consumer-static.azureedge.net/mouse-gesture/config.json
Method	GET
Attack	
Evidence	
Other	

Info	
URL	https://edge.microsoft.com/serviceexperimentation/v3/?osname=win&channel=stable&osver=10.0.17821.49919&devicefamily=desktop&installdate=1782149919&clientversion=149.0.4022.80&experimentationid=149.0.4022.80
Node Name	https://edge.microsoft.com/serviceexperimentation/v3/ (channel,clientversion,devicefamily,experimentationid,scpguard,scpver)
Method	GET
Attack	
Evidence	
Other Info	
URL	https://fonts.gstatic.com/s/inter/v20/UcC73FwrK3iLTeHuS_nVMrMxCp50Sjla1ZL7.woff2
Node Name	https://fonts.gstatic.com/s/inter/v20/UcC73FwrK3iLTeHuS_nVMrMxCp50Sjla1ZL7.woff2
Method	GET
Attack	
Evidence	
Other Info	
URL	https://fonts.gstatic.com/s/jetbrainsmono/v24/tDbv2o-flEEHy0FZhsfKu5WU4zr3E_BX0PnT8RD8
Node Name	https://fonts.gstatic.com/s/jetbrainsmono/v24/tDbv2o-flEEHy0FZhsfKu5WU4zr3E_BX0PnT8RD8
Method	GET
Attack	
Evidence	
Other Info	
URL	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Node Name	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Method	GET
Attack	
Evidence	
Other Info	
URL	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Node Name	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Method	GET
Attack	
Evidence	
Other Info	
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3
Node Name	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3 (){{identity:{user:locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},c{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugI

Method	POST
Attack	
Evidence	
Other Info	
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3
Node Name	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3 ()({identity:{user locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},c {topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugl
Method	POST
Attack	
Evidence	
Other Info	
URL	https://edge.microsoft.com/componentupdater/api/v1/update
Node Name	https://edge.microsoft.com/componentupdater/api/v1/update ()({request:{@os,@updater,accept [{download_time_ms,downloaded,downloader,eventresult,eventtype,nextversion,pipeline_id,pre nextversion,pipeline_id,previousversion},{eventresult,eventtype,install_time_ms,nextversion,pre domainjoined,hw:{avx,physmemory,sse,sse2,sse3,sse41,sse42,ssse3},ismachine,os:{arch,platf sessionid,updatervers...})
Method	POST
Attack	
Evidence	
Other Info	
URL	https://edge.microsoft.com/componentupdater/api/v1/update?cup2key=7:Rvb3vISQ370NxLCt7z4NiSvWjvOuR8&cup2hreq=41e68f727392b3846a977d18b568661784db32e60c1dd59c12ce8dc
Node Name	https://edge.microsoft.com/componentupdater/api/v1/update (cup2hreq,cup2key)({request:{@os enabled,installdate,installsource,lang,model_locale,ping:{r},targetingattributes:{AppCohort,AppM Priority,Updater,UpdaterVersion},updatecheck:{},version}},arch,dedup,domainjoined,hw:{avx,ph ismachine,os:{arch,platform,version},prodversion,protocol,requestid,sessionid,updaters:{autoup laststarted,name,updatepolicy,versi...})
Method	POST
Attack	
Evidence	
Other Info	
URL	https://edge.microsoft.com/componentupdater/api/v1/update?cup2key=7:1uyNqhMbunMMP3bfR26JCxZVA&cup2hreq=ecdb4be3119bbe7b77ab84b5b757ffc865235ec132650f276aabcb7104
Node Name	https://edge.microsoft.com/componentupdater/api/v1/update (cup2hreq,cup2key)({request:{@os enabled,installdate,installsource,lang,ping:{r},targetingattributes:{AppCohort,AppMajorVersion,A Updater,UpdaterVersion},updatecheck:{},version}},arch,dedup,domainjoined,hw:{avx,physmemc os:{arch,platform,version},prodversion,protocol,requestid,sessionid,updaters:{autoupdatechecke updatepolicy,version},updaterve...})
Method	POST
Attack	
Evidence	
Other Info	
	https://edge.microsoft.com/componentupdater/api/v1/update?cup2key=7:

URL	3GTukHKHMKtq6aBxR7r0YwiGCMCqpCf833AcTVRR9xY&cup2hreq=a1f53b7cb46cb77924c9!
Node Name	https://edge.microsoft.com/componentupdater/api/v1/update (cup2hreq,cup2key)({request: {@os enabled,installdate,lang,ping:{r},targetingattributes:{AppCohort,AppMajorVersion,AppRollout,AppUpdaterVersion},updatecheck:{},version}},arch,dedup,domainjoined,hw:{avx,physmemory,sse,splatform,version},prodversion,protocol,requestid,sessionid,updaters:{autoupdatecheckenabled,iupdatepolicy,version},updaterversion}))
Method	POST
Attack	
Evidence	
Other Info	
URL	https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3
Node Name	https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3 ()({userAgent,redirect,referrerChain:[]},identity:{user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,c customSettings}}},config:{user:{uriReputation:{enforcedByPolicy,level}},device:{appControl:{leve destination:{uri,ip},...})
Method	POST
Attack	
Evidence	
Other Info	
URL	https://telem-edge.smartscreen.microsoft.com/api/browser/edge/telemetry/3
Node Name	https://telem-edge.smartscreen.microsoft.com/api/browser/edge/telemetry/3 ()({executionTime,r cacheHit},config:{user:{uriReputation:{enforcedByPolicy,level}},device:{appControl:{level},appRe identity:{user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{intern architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLoc userAgent,events:[{...})
Method	POST
Attack	
Evidence	
Other Info	
URL	https://telem-edge.smartscreen.microsoft.com/api/browser/edge/telemetry/3
Node Name	https://telem-edge.smartscreen.microsoft.com/api/browser/edge/telemetry/3 ()({executionTime,r config:{user:{uriReputation:{enforcedByPolicy,level}},device:{appControl:{level},appReputation:{ {user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplor architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLoc userAgent,events:[{\$type,nam...})
Method	POST
Attack	
Evidence	
Other Info	
URL	https://www.googleapis.com/chromewebstore/v1.1/items/verify
Node Name	https://www.googleapis.com/chromewebstore/v1.1/items/verify ()({hash,ids:[],protocol_version}))
Method	POST
Attack	
Evidence	

Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to enforce Stri
Reference	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet https://owasp.org/www-community/Security-Headers https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security https://caniuse.com/stricttransportsecurity https://datatracker.ietf.org/doc/html/rfc6797
CWE Id	319
WASC Id	15
Plugin Id	10035

Low	Timestamp Disclosure - Unix
Description	A timestamp was disclosed by the application/web server. - Unix
URL	http://localhost:5173/node_modules/.vite/deps/react-dom_client.js?v=199ca72e
Node Name	http://localhost:5173/node_modules/.vite/deps/react-dom_client.js (v)
Method	GET
Attack	
Evidence	2080374784
Other Info	2080374784, which evaluates to: 2035-12-04 15:23:04.
URL	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Node Name	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Method	GET
Attack	
Evidence	1782149924
Other Info	1782149924, which evaluates to: 2026-06-22 23:08:44.
URL	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Node Name	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Method	GET
Attack	
Evidence	1782149925
Other Info	1782149925, which evaluates to: 2026-06-22 23:08:45.
URL	https://edge.microsoft.com/componentupdater/api/v1/update
Node Name	https://edge.microsoft.com/componentupdater/api/v1/update ()({request:{@os,@updater,accept [{download_time_ms,downloaded,downloader,eventresult,eventtype,nextversion,pipeline_id,pre nextversion,pipeline_id,previousversion},{eventresult,eventtype,install_time_ms,nextversion,pre domainjoined,hw:{avx,physmemory,sse,sse2,sse3,sse41,sse42,ssse3},ismachine,os:{arch,platf sessionid,updatervers...})
Method	POST
Attack	
Evidence	1782348352

Other Info	1782348352, which evaluates to: 2026-06-25 06:15:52.
URL	https://edge.microsoft.com/componentupdater/api/v1/update?cup2key=7:Rvb3vISQ370NxLCt7z4NiSwWjvOuR8&cup2hreq=41e68f727392b3846a977d18b568661784db32e60c1dd59c12ce8dc
Node Name	https://edge.microsoft.com/componentupdater/api/v1/update (cup2hreq,cup2key)({request:{@os enabled,installdate,installsource,lang,model_locale,ping:{r},targetingattributes:{AppCohort,AppM Priority,Updater,UpdaterVersion},updatecheck:{},version}},arch,dedup,domainjoined,hw:{avx,ph ismachine,os:{arch,platform,version},prodversion,protocol,requestid,sessionid,updaters:{autoup laststarted,name,updatepolicy,versi...})
Method	POST
Attack	
Evidence	1782329345
Other Info	1782329345, which evaluates to: 2026-06-25 00:59:05.
URL	https://edge.microsoft.com/componentupdater/api/v1/update?cup2key=7:1uyNqhMbunMMP3bfR26JCxZVA&cup2hreq=ecdb4be3119bbe7b77ab84b5b757ffc865235ec132650f276aabcb7104
Node Name	https://edge.microsoft.com/componentupdater/api/v1/update (cup2hreq,cup2key)({request:{@os enabled,installdate,installsource,lang,ping:{r},targetingattributes:{AppCohort,AppMajorVersion,A Updater,UpdaterVersion},updatecheck:{},version}},arch,dedup,domainjoined,hw:{avx,physmemc os:{arch,platform,version},prodversion,protocol,requestid,sessionid,updaters:{autoupdatechecke updatepolicy,version},updaterve...})
Method	POST
Attack	
Evidence	1782348352
Other Info	1782348352, which evaluates to: 2026-06-25 06:15:52.
URL	https://edge.microsoft.com/componentupdater/api/v1/update?cup2key=7:j2NR85_TwjibVPHNT0cJQwrBVi9376QJ_CljeWecuMI&cup2hreq=7916a187a96fc9bebf50d69
Node Name	https://edge.microsoft.com/componentupdater/api/v1/update (cup2hreq,cup2key)({request:{@os enabled,installdate,installsource,lang,ping:{r},targetingattributes:{AppCohort,AppMajorVersion,A Updater,UpdaterVersion},updatecheck:{},version}},arch,dedup,domainjoined,hw:{avx,physmemc os:{arch,platform,version},prodversion,protocol,requestid,sessionid,updaters:{autoupdatechecke updatepolicy,version},updaterve...})
Method	POST
Attack	
Evidence	1782374071
Other Info	1782374071, which evaluates to: 2026-06-25 13:24:31.
URL	https://edge.microsoft.com/componentupdater/api/v1/update?cup2key=7:3GTukHKHMKtq6aBxR7r0YwiGCMCqpCf833AcTVRR9xY&cup2hreq=a1f53b7cb46cb77924c9!
Node Name	https://edge.microsoft.com/componentupdater/api/v1/update (cup2hreq,cup2key)({request:{@os enabled,installdate,lang,ping:{r},targetingattributes:{AppCohort,AppMajorVersion,AppRollout,Ap UpdaterVersion},updatecheck:{},version}},arch,dedup,domainjoined,hw:{avx,physmemory,sse,s platform,version},prodversion,protocol,requestid,sessionid,updaters:{autoupdatecheckenabed,i updatepolicy,version},updaterversion}})
Method	POST
Attack	
Evidence	1782415541
Other Info	1782415541, which evaluates to: 2026-06-26 00:55:41.
Instances	Systemic

Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated
Reference	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Low	X-AspNet-Version Response Header
Description	Server leaks information via "X-AspNet-Version"/"X-AspNetMvc-Version" HTTP response header field(s).
URL	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/2b43081f-d6ff-4406-bbb9-c327fccbcb45?P1=1782329345&P2=404&P3=2&P4=F1VxUvS9DQm388w%2b2Xy8S1Eo7vIAb3iXkhOY4Ox16ZYPvY2GsE8%2bL0RakrsAP4vQ%2fIPj%2b84ZVM5ylAMz9iOP5Q%3d%3d
Node Name	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/2b43081f-d6ff-4406-bbb9-c327fccbcb45 (P1,P2,P3,P4)
Method	GET
Attack	
Evidence	4.0.30319
Other Info	An attacker can use this information to exploit known vulnerabilities.
URL	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/2b43081f-d6ff-4406-bbb9-c327fccbcb45?P1=1782329345&P2=404&P3=2&P4=F1VxUvS9DQm388w%2b2Xy8S1Eo7vIAb3iXkhOY4Ox16ZYPvY2GsE8%2bL0RakrsAP4vQ%2fIPj%2b84ZVM5ylAMz9iOP5Q%3d%3d
Node Name	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/2b43081f-d6ff-4406-bbb9-c327fccbcb45 (P1,P2,P3,P4)
Method	GET
Attack	
Evidence	5.3
Other Info	An attacker can use this information to exploit known vulnerabilities.
URL	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/954c48e2-6a88-44a1-a49e-0fcfaad93f67?P1=1782374071&P2=404&P3=2&P4=BaYf3mCTpsayJ0bhgiEzMu%2bXr3U3SdGMSRpuAnCFXUOaxyRNIDGoANYuF2oAO01zev0O38xSnXI5y4Ao50eTUw%3d%3d
Node Name	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/954c48e2-6a88-44a1-a49e-0fcfaad93f67 (P1,P2,P3,P4)
Method	GET
Attack	
Evidence	4.0.30319
Other Info	An attacker can use this information to exploit known vulnerabilities.
URL	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/954c48e2-6a88-44a1-a49e-0fcfaad93f67?P1=1782374071&P2=404&P3=2&P4=BaYf3mCTpsayJ0bhgiEzMu%2bXr3U3SdGMSRpuAnCFXUOaxyRNIDGoANYuF2oAO01zev0O38xSnXI5y4Ao50eTUw%3d%3d
Node Name	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/954c48e2-6a88-44a1-a49e-0fcfaad93f67 (P1,P2,P3,P4)
Method	GET

Attack	
Evidence	5.3
Other Info	An attacker can use this information to exploit known vulnerabilities.
Instances	4
Solution	Configure the server so it will not return those headers.
Reference	https://www.troyhunt.com/shhh-dont-let-your-response-headers/ https://learn.microsoft.com/en-us/archive/blogs/varunm/remove-unwanted-http-response-headers
CWE Id	933
WASC Id	14
Plugin Id	10061

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://localhost:5173/
Node Name	http://localhost:5173/
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5173/node_modules/vite/deps/react.js?v=199ca72e
Node Name	http://localhost:5173/node_modules/vite/deps/react.js (v)
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5173/node_modules/vite/dist/client/env.mjs
Node Name	http://localhost:5173/node_modules/vite/dist/client/env.mjs
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.

URL	http://localhost:5173/src/App.css
Node Name	http://localhost:5173/src/App.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5173/src/index.css
Node Name	http://localhost:5173/src/index.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:8080/api/greet?name=a
Node Name	http://localhost:8080/api/greet (name)
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/2b43081f-d6ff-4406-bbb9-c327fccbcb45?P1=1782329345&P2=404&P3=2&P4=F1VxUvS9DQm388w%2b2Xy8S1Eo7vIAb3iXkhQY4Ox16ZYPvY2GsE8%2bL0RakrsAP4vQ%2fIPj%2b84ZVM5ylAMz9iOP5Q%3d%3d
Node Name	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/2b43081f-d6ff-4406-bbb9-c327fccbcb45 (P1,P2,P3,P4)
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/954c48e2-6a88-44a1-a49e-0fcfaad93f67?P1=1782374071&P2=404&P3=2&P4=BaYf3mCTpsayJ0bhgiEzMu%2b3U3SdGMSRpuAnCFXUOaxyRNIDGoANYuF2oAO01zev0O38xSnXI5y4Ao50eTUw%3d%3d
Node Name	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/954c48e2-6a88-44a1-a49e-0fcfaad93f67 (P1,P2,P3,P4)
Method	GET

Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/dadee85a-ef0f-411e-a9da-4f5235a4c9e4?P1=1782348352&P2=404&P3=2&P4=f9%2fXliBStvETDL6hBApOgQ0oBE73Rcsxz8QRbCk3rluCt2KAJ9F%2bIREStn8Sec94I%2fY7BxpWWXYsDbgNQhyWlQ%3d%3d
Node Name	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/dadee85a-ef0f-411e-a9da-4f5235a4c9e4 (P1,P2,P3,P4)
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://edge-consumer-static.azureedge.net/mouse-gesture/config.json
Node Name	https://edge-consumer-static.azureedge.net/mouse-gesture/config.json
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://edge.microsoft.com/abusiveadblocking/api/v1/blocklist
Node Name	https://edge.microsoft.com/abusiveadblocking/api/v1/blocklist
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://edge.microsoft.com/autofillservice/core/page/3693946771987704403/-4719149458570120938
Node Name	https://edge.microsoft.com/autofillservice/core/page/3693946771987704403/-4719149458570120938
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
	https://edge.microsoft.com/autofillservice/core/page/3693946771987704403

URL	/5309080670790986136
Node Name	https://edge.microsoft.com/autofillservice/core/page/3693946771987704403/5309080670790986136
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://edge.microsoft.com/autofillservice/core/page/3693946771987704403/750765281418421961
Node Name	https://edge.microsoft.com/autofillservice/core/page/3693946771987704403/750765281418421961
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://edge.microsoft.com/serviceexperimentation/v3/?osname=win&channel=stable&osver=10.0.26200&devicefamily=desktop&installdate=1782149919&clientversion=149.0.4022.80&experimentationmode=2&scpguard=0&scpfll=0&scpver=0
Node Name	https://edge.microsoft.com/serviceexperimentation/v3/ (channel,clientversion,devicefamily,experimentationmode,installdate,osname,osver,scpfll,scpguard,scpver)
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Node Name	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Node Name	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Method	GET
Attack	
Evidence	

Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:8080/api/login
Node Name	http://localhost:8080/api/login ()(password,username)
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3
Node Name	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/settings/3 ()({identity: {user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugInfo:{clientId}})
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3
Node Name	https://data-edge.smartscreen.microsoft.com/api/browser/edge/data/toptraffic/3 ()({identity: {user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},correlationId,debugInfo:{clientId}})
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3
Node Name	https://nav-edge.smartscreen.microsoft.com/api/browser/edge/navigate/3 ()({userAgent,redirectChain:[],enhancedRedirectChain:{redirectSource,referrerChain:[]},identity:{user:{locale},device:{id,customId,onlineIdTicket,family,locale,osVersion,browser:{internetExplorer},netJoinStatus,enterprise:{},cloudSku,architecture},caller:{locale,name,version},client:{version,data:{topTraffic,customSynchronousLookupUris,edgeSettings,customSettings}}},config:{user:{uriReputation:{enforcedByPolicy,level}},device:{appControl:{level},appReputation:{enforcedByPolicy,level}}},destination:{uri,ip},...)
Method	POST
Attack	
Evidence	
	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still

Other Info	affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Authentication Request Identified
Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	http://localhost:8080/api/login
Node Name	http://localhost:8080/api/login ()(password,username)
Method	POST
Attack	
Evidence	password
Other Info	userParam=username userValue=a passwordParam=password referer=http://localhost:5173/
Instances	1
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informational	Information Disclosure - Sensitive Information in URL
Description	The request appeared to contain sensitive information leaked in the URL. This can violate PCI and most organizational compliance policies. You can configure the list of strings for this check to add or remove values specific to your environment.
URL	http://localhost:5173/?token=IP2bYDaLCsEa
Node Name	http://localhost:5173/ (token)
Method	GET
Attack	
Evidence	token
Other Info	The URL contains potentially sensitive information. The following string was found via the pattern: token token
Instances	1

Solution	Do not pass sensitive information in URIs.
Reference	
CWE Id	598
WASC Id	13
Plugin Id	10024

Informational	Information Disclosure - Suspicious Comments
Description	The response appears to contain suspicious comments which may help an attacker.
URL	http://localhost:5173/
Node Name	http://localhost:5173/
Method	GET
Attack	
Evidence	<div id="root"> is where React mounts your e
Other Info	The following pattern was used: \bWHERE\b and was detected in likely comment: "<!-- This single <div id="root"> is where React mounts your entire app. React's virtual DOM replaces this element's ", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/@react-refresh
Node Name	http://localhost:5173/@react-refresh
Method	GET
Attack	
Evidence	// TODO: rename these field
Other Info	The following pattern was used: \bTODO\b and was detected in likely comment: "// TODO: rename these fields to something more meaningful.", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/@react-refresh
Node Name	http://localhost:5173/@react-refresh
Method	GET
Attack	
Evidence	ogic is copy-pasted from similar logic in th
Other Info	The following pattern was used: \bFROM\b and was detected 2 times, the first in likely comment: "// This logic is copy-pasted from similar logic in the DevTools backend.", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/App.jsx
Node Name	http://localhost:5173/src/App.jsx
Method	GET
Attack	
Evidence	the "result" field from the JSON
Other Info	The following pattern was used: \bFROM\b and was detected in likely comment: "// Update state with the "result" field from the JSON", see evidence field for the suspicious comment /snippet.
URL	http://localhost:5173/src/App.jsx
Node Name	http://localhost:5173/src/App.jsx

Method	GET
Attack	
Evidence	ample: * const [query, setQuery] = useSta
Other Info	The following pattern was used: \bQUERY\b and was detected 4 times, the first in likely comment: "/* * ===== * MODULE 6: THE MAIN APP COMPONENT (App.jsx) * =====", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/App.jsx
Node Name	http://localhost:5173/src/App.jsx
Method	GET
Attack	
Evidence	ce: we send the raw user input to the backen
Other Info	The following pattern was used: \bUSER\b and was detected 2 times, the first in likely comment: "// Notice: we send the raw user input to the backend.", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/App.jsx
Node Name	http://localhost:5173/src/App.jsx
Method	GET
Attack	
Evidence	ooks like: username=admin&password=password12
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "// Body looks like: username=admin&password=password123", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/App.jsx
Node Name	http://localhost:5173/src/App.jsx
Method	GET
Attack	
Evidence	rlencoded makes the username
Other Info	The following pattern was used: \bUSERNAME\b and was detected in likely comment: "// Using application/x-www-form-urlencoded makes the username", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/main.jsx
Node Name	http://localhost:5173/src/main.jsx
Method	GET
Attack	
Evidence	d ReactDOM.render() from React 17)
Other Info	The following pattern was used: \bFROM\b and was detected in likely comment: "// (replaces the old ReactDOM.render() from React 17)", see evidence field for the suspicious comment/snippet.
URL	http://localhost:5173/src/main.jsx
Node Name	http://localhost:5173/src/main.jsx
Method	GET
Attack	

Evidence	e (in dev) to catch bugs * Has NO effect i
Other Info	The following pattern was used: \bBUGS\b and was detected in likely comment: "/* * ===== * MODULE 5: REACT ENTRY POINT (main.jsx) * =====", see evidence field for the suspicious comment/snippet.
Instances	10
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	Loosely Scoped Cookie
Description	Cookies can be scoped by domain or path. This check is only concerned with domain scope. The domain scope applied to a cookie determines which domains can access it. For example, a cookie can be scoped strictly to a subdomain e.g. www.nottrusted.com, or loosely scoped to a parent domain e.g. nottrusted.com. In the latter case, any subdomain of nottrusted.com can access the cookie. Loosely scoped cookies are common in mega-applications like google.com and live.com. Cookies set from a subdomain like app.foo.bar are transmitted only to that domain by the browser. However, cookies scoped to a parent-level domain may be transmitted to the parent, or any subdomain of the parent.
URL	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Node Name	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Method	GET
Attack	
Evidence	domain=bing.com
Other Info	The origin domain used for comparison was: www.bing.com Cookie name: _EDGE_S Cookie name: _EDGE_V Cookie name: MUID
Instances	1
Solution	Always scope cookies to a FQDN (Fully Qualified Domain Name).
Reference	https://datatracker.ietf.org/doc/html/rfc6265#section-4.1 https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html https://code.google.com/archive/p/browsersec/wikis/Part2.wiki
CWE Id	565
WASC Id	15
Plugin Id	90033

Informational	Modern Web Application
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	http://localhost:5173/
Node Name	http://localhost:5173/
Method	GET
Attack	
Evidence	<script type="module">import { injectIntoGlobalHook } from "@react-refresh"; injectIntoGlobalHook(window); window.\$RefreshReg\$ = () => {}; window.\$RefreshSig\$ = ()

	=> (type) => type;</script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	1
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Informational	Re-examine Cache-control Directives
Description	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.
URL	https://edge-consumer-static.azureedge.net/mouse-gesture/config.json
Node Name	https://edge-consumer-static.azureedge.net/mouse-gesture/config.json
Method	GET
Attack	
Evidence	public, max-age=432000
Other Info	
URL	https://edge.microsoft.com/abusiveadblocking/api/v1/blocklist
Node Name	https://edge.microsoft.com/abusiveadblocking/api/v1/blocklist
Method	GET
Attack	
Evidence	public, max-age=43200
Other Info	
URL	https://edge.microsoft.com/autofillservice/core/page/3693946771987704403/-4719149458570120938
Node Name	https://edge.microsoft.com/autofillservice/core/page/3693946771987704403/-4719149458570120938
Method	GET
Attack	
Evidence	max-age=691200
Other Info	
URL	https://edge.microsoft.com/autofillservice/core/page/3693946771987704403/-5309080670790986136
Node Name	https://edge.microsoft.com/autofillservice/core/page/3693946771987704403/-5309080670790986136
Method	GET
Attack	
Evidence	max-age=691200

Other Info	
URL	https://edge.microsoft.com/autofillservice/core/page/3693946771987704403/750765281418421961
Node Name	https://edge.microsoft.com/autofillservice/core/page/3693946771987704403/750765281418421961
Method	GET
Attack	
Evidence	max-age=691200
Other Info	
URL	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Node Name	https://www.bing.com/bloomfilterfiles/ExpandedDomainsFilterGlobal.json
Method	GET
Attack	
Evidence	
Other Info	
Instances	6
Solution	For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control https://grayduck.mn/2021/09/13/cache-control-recommendations/
CWE Id	525
WASC Id	13
Plugin Id	10015

Informational	Retrieved from Cache
Description	The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
URL	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/2b43081f-d6ff-4406-bbb9-c327fccbcb45?P1=1782329345&P2=404&P3=2&P4=F1VxUvS9DQm388w%2b2Xy8S1Eo7vIAb3iXkhOY4Ox16ZYPvY2GsE8%2bL0RakrsAP4vQ%2flPj%2b84ZVM5ylAMz9iOP5Q%3d%3d
Node Name	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/2b43081f-d6ff-4406-bbb9-c327fccbcb45 (P1,P2,P3,P4)
Method	GET
Attack	
Evidence	Age: 7587960
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/954c48e2-6a88-

URL	44a1-a49e-0fcfaad93f67?P1=1782374071&P2=404&P3=2&P4=BaYf3mCTpsayJ0bhgiEzMu%2bxr3U3SdGMSRpuAnCFXUOaxyRNIDGoANYuF2oAO01zev0O38xSnXI5y4Ao50eTUw%3d%3d
Node Name	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/954c48e2-6a88-44a1-a49e-0fcfaad93f67 (P1,P2,P3,P4)
Method	GET
Attack	
Evidence	Age: 7588574
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/dadee85a-ef0f-411e-a9da-4f5235a4c9e4?P1=1782348352&P2=404&P3=2&P4=f9%2fXliBStvETDL6hBApOgQ0oBE73Rcsxz8QRbCk3rluCt2KAJ9F%2bIREStn8Sec94I%2fY7BxpWWXYsDbgNQhyWlQ%3d%3d
Node Name	http://msedge.f.tlu.dl.delivery.mp.microsoft.com/filestreamingservice/files/dadee85a-ef0f-411e-a9da-4f5235a4c9e4 (P1,P2,P3,P4)
Method	GET
Attack	
Evidence	Age: 1798798
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://fonts.gstatic.com/s/inter/v20/UcC73FwrK3iLTeHuS_nVMrMxCp50Sjla1ZL7.woff2
Node Name	https://fonts.gstatic.com/s/inter/v20/UcC73FwrK3iLTeHuS_nVMrMxCp50Sjla1ZL7.woff2
Method	GET
Attack	
Evidence	Age: 389394
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
URL	https://fonts.gstatic.com/s/jetbrainsmono/v24/tDbv2o-flEEEny0FZhsfKu5WU4zr3E_BX0PnT8RD8yKwBNntkaToggR7BYRbKPxDcwg.woff2
Node Name	https://fonts.gstatic.com/s/jetbrainsmono/v24/tDbv2o-flEEEny0FZhsfKu5WU4zr3E_BX0PnT8RD8yKwBNntkaToggR7BYRbKPxDcwg.woff2
Method	GET
Attack	
Evidence	Age: 406639
Other Info	The presence of the 'Age' header indicates that a HTTP/1.1 compliant caching server is in use.
Instances	5
Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0

	This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.rfc-editor.org/rfc/rfc9110.html
CWE Id	525
WASC Id	
Plugin Id	10050

Informational	Session Management Response Identified
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Node Name	https://www.bing.com/api/shopping/v1/user/shoppingsettings
Method	GET
Attack	
Evidence	MUIDB
Other Info	cookie:MUIDB cookie:_EDGE_S cookie:MUID
Instances	1
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	
Plugin Id	10112

Informational	User Agent Fuzzer
Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	http://localhost:8080
Node Name	http://localhost:8080
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://localhost:8080/api
Node Name	http://localhost:8080/api
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	

Other Info	
URL	http://localhost:8080/api/login
Node Name	http://localhost:8080/api/login
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://localhost:8080/robots.txt
Node Name	http://localhost:8080/robots.txt
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
URL	http://localhost:8080/script
Node Name	http://localhost:8080/script
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
Instances	Systemic
Solution	
Reference	https://owasp.org/wstg
CWE Id	
WASC Id	
Plugin Id	10104